

UNIVERSITY OF MAURITIUS

FACULTY OF INFORMATION, COMMUNICATION AND DIGITAL TECHNOLOGIES



SECOND SEMESTER EXAMINATIONS

APRIL/MAY 2019

PROGRAMME	BSc (Hons) Information Systems - E311		
MODULE NAME	Information Systems Security		
DATE	Friday 10 May 2019	MODULE CODE	CSE3118Y
TIME	09.45-12.45 hrs	DURATION	3 Hours
NO. OF QUESTIONS SET	5	NO. OF QUESTIONS TO BE ATTEMPTED	5

INSTRUCTIONS TO CANDIDATES

Answer ALL questions.

All questions carry equal marks.

Answer all questions.

All questions carry equal marks.

Question 1

(a) Explain briefly how each of the following attacks takes place:

- Denial of Service (DoS)
- Distributed Denial of Service (DDoS)
- Buffer Overflow
- Man-in-the-Middle

[4 marks]

(b) Discuss the key elements of a good **password policy** that can be adopted for email accounts.

[5 marks]

(c) With the help of a labelled diagram, explain the design of a **password-based authentication model** that will not be susceptible to replay attacks and verifier compromise.

[6 marks]

(d) (i) Explain how SQL injection vulnerability works.

[3 marks]

(ii) Discuss a method to prevent SQL injection attacks.

[2 marks]

(Total: 20 Marks)

(continued next page)

Question 2

(a) Explain, with a suitable example, the principle of operation for the following cryptosystems between user A (a sender) and user B (a receiver):

- Symmetric cryptosystems
- Asymmetric cryptosystems

[6 marks]

(b) (i) Explain the aim behind implementation of Secure Socket Layer (SSL) / Transport Layer Security (TLS) protocol.

[2 marks]

(ii) Describe the steps involved in the Secure Socket Layer (SSL) handshake protocol between client (browser) and server.

[8 marks]

(c) (i) Explain the difference between Polymorphic and Metamorphic viruses.

[2 marks]

(ii) Discuss briefly the solutions for protecting against computing viruses.

[2 marks]

(Total: 20 Marks)

Question 3

(a) Explain the operation and state the strengths and weaknesses for each of the following types of firewall technology:

- Simple Packet Filters
- Stateful Packet Filters
- Circuit Level Gateways
- Application Gateways

[8 marks]

(continued next page)

- (b) Consider a packet filtering firewall placed between a LAN and the Internet as shown in the **Figure 1** below, where the labels on the arrows indicate the physical ports on the firewall router. The LAN hosts inside the firewall have IP addresses described by the regular expression **240.155.16.***.

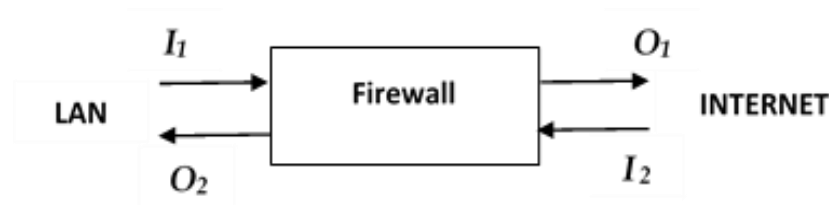


Figure 1 Question 3(b)

The filter table for port I_1 is:

Line	Action	Source IP	Source Port	Destination IP	Destination Port
1.	Allow	240.155.16.*	*	*	*
2.	Block	*	*	*	*

Table 1

The filter table for port I_2 is:

Line	Action	Source IP	Source Port	Destination IP	Destination Port
1.	Block	158.214.5.*	80	240.155.16.*	*
2.	Allow	*	80	240.155.16.*	*
3.	Allow	*	*	240.144.16.3	25
4.	Block	*	*	*	*

Table 2

The filter tables for ports O_1 and O_2 permit *all* traffic.

- (i) For each of the following packet descriptions arriving at port I_2 of the firewall, determine which line of I_2 's filter table will be used to decide whether the packet is Blocked or Allowed.

	Source IP	Source Port	Destination IP	Destination Port
Packet P_1	158.214.5.2	2400	240.155.16.3	23
Packet P_2	128.7.244.129	80	240.155.16.3	6002
Packet P_3	128.7.244.129	25	240.155.16.3	23
Packet P_4	158.214.5.12	80	240.144.16.3	25

[4 marks]

(continued next page)

- (ii) Suggest any benefit of configuring the filter table on port I_1 as above in **Table 1**.
[1 mark]
- (c) Intrusion detection systems (IDS) are automated systems (programs) that detect suspicious events and can be either **host-based** or **network-based**.
- (i) State an advantage and a disadvantage of host-based IDS and network-based IDS.
[4 marks]
- (ii) Suggest three problems which both types of IDS can suffer from.
[3 marks]
- (Total: 20 Marks)**

Question 4

- (a) (i) Explain the difference between a **threat**, **vulnerability**, and a **risk** in the context of information security.
[3 marks]
- (ii) An information security risk assessment consists of Risk Identification, Risk analysis and Risk evaluation. State the main purpose of doing risk identification and outline the expected output of this process.
[3 marks]
- (iii) Compare and contrast between **qualitative** risk analysis and **quantitative** risk analysis methodologies for an information security risk assessment.
[4 marks]
- (b) A local company *BizIT* owns a LAN comprising 2500 computers. The company has suffered three extensive virus outbreaks on its internal network in the last five years. These three events have cost *BizIT* \$16,000, \$8,000 and \$12,000, respectively in lost time and effort to recover.
- (i) Given this information, what is the ARO and ALE?
[2 marks]
- (ii) A vendor has proposed a new anti-virus solution whose 5-year license and maintenance fees are \$12,000, and is estimated to reduce the probability of a virus outbreak to just one in nine years.

Prove whether this solution/control is cost-effective or not.

[5 marks]

(continued next page)

- (iii) Another possible solution is that *BizIT* completely abandons hosting and maintaining a private LAN, and instead migrates into the Cloud. In that case, the Cloud provider would be responsible for preventing and dealing with virus infections.

What would be the highest price of 'per-computer' Cloud hosting to make this solution cost-effective for *BizIT*?

[3 marks]

(Total: 20 Marks)

Question 5

- (a) (i) Explain the difference between a disaster recovery plan and a business continuity plan.

[2 marks]

- (ii) Describe briefly the steps usually present in a Business Continuity Process.

[5 marks]

- (b) (i) **Figure 2** shows a network design supporting a web site. Discuss how the design components provide a « **high-availability** » solution for business continuity.

[6 marks]

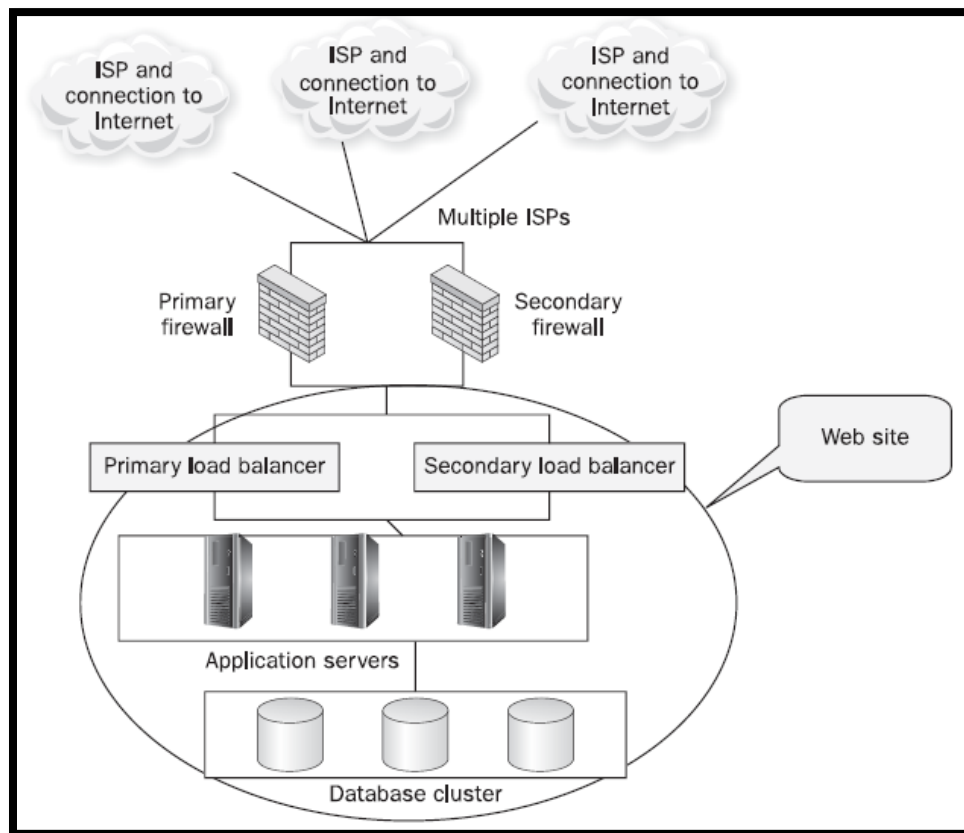


Figure 2

(continued next page)

- (ii) A network device is expected to operate for 2000 hours after repair, and the mean repair time is expected to be ten hours. Determine the availability of the device.
[2 marks]
- (c) If an organisation suffers physical damage of its computing facilities, having offsite storage of data is only part of a solution for restoring operations. This data will need to be processed somewhere else. Suggest and describe five recovery strategies for alternative site processing.

[5 marks]
(Total: 20 Marks)

END OF QUESTION PAPER